

HIDDEN ENDPOINT DISCOVERY WITH KITERUNNER

API route discovery, undocumented path identification, and inventory risk analysis

Field	Details
Module	Sub-Project 2 - API Security Testing Lab
Document Type	Individual API Security Methodology PDF
Phase / Test Case	Phase 8 - Hidden Endpoint Discovery
Prepared For	GitHub Portfolio Documentation
Prepared By	Jagriti Banerjee
Repository	Enterprise-Security-Assessment-Lab
GitHub Filename	08-hidden-endpoint-discovery-methodology-report.pdf

This document is a professional, evidence-driven explanation of one API security methodology section. It is designed for portfolio review and contains only authorized lab-based testing context. Sensitive token values, account data, cookies, and private identifiers are redacted or intentionally represented with placeholders.

1. Section Overview

Area	Details
Phase	Phase 8 - Hidden Endpoint Discovery
Objective	Identify hidden or undocumented API routes that may not be visible through the frontend or official request collection.
Primary Result	Evidence captured and methodology documented
GitHub Folder	02-api-security/reports/methodology/

Why this section matters

Hidden endpoint discovery is closely linked to API inventory management. The security issue is not merely that a route exists; the issue is whether unknown or legacy routes bypass the controls applied to documented endpoints.

2. Evidence Embedded in This PDF

Evidence 1:

10-kiterunner-hidden-endpoints-discovered.png

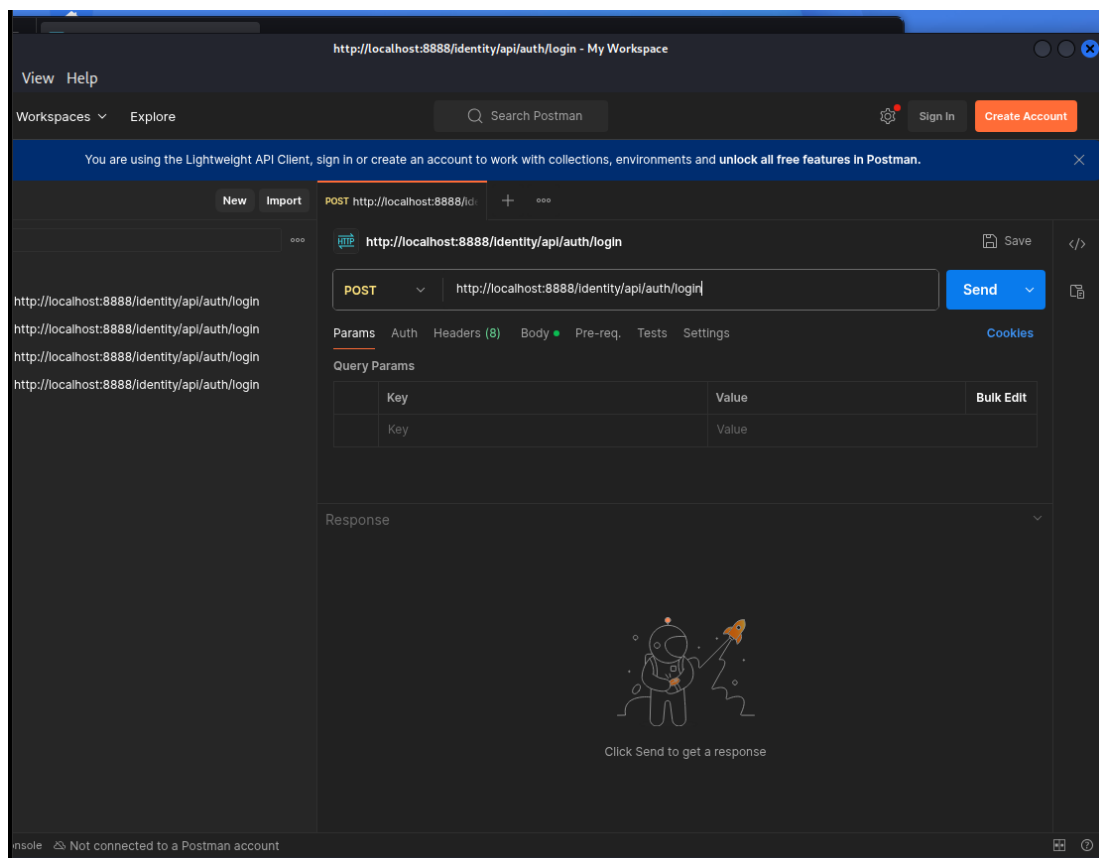


Figure 1 - Kiterunner evidence showing discovered API endpoints for mapping and follow-up testing.

Kiterunner evidence showing discovered API endpoints for mapping and follow-up testing.

3. Command and Workflow Used

```
kr scan http://127.0.0.1:8888 \  
-w /usr/share/wordlists/kiterunner/routes-small.kite  
  
# Follow-up workflow  
# 1. Review discovered paths  
# 2. Test authentication requirement  
# 3. Test authorization requirement  
# 4. Add valid endpoints to Postman collection
```

Step-by-step workflow

- Ran Kiterunner against the local lab API base URL.
- Reviewed discovered API routes and response behaviour.
- Flagged routes for authentication and authorization validation.
- Mapped useful routes into the API testing workflow.

4. Professional Interpretation

Hidden endpoint discovery is closely linked to API inventory management. The security issue is not merely that a route exists; the issue is whether unknown or legacy routes bypass the controls applied to documented endpoints.

5. Security Risk and Impact

Undocumented endpoints may expose old business logic, test functionality, admin operations, versioned routes, or weaker validation paths. Attackers can discover these endpoints and test them for broken access control or data exposure.

6. Recommended Remediation and Hardening

- Maintain a complete and current API inventory.
- Remove deprecated routes and unused API versions.
- Apply centralized authentication and authorization to every route.
- Use API gateway policies to block unmanaged paths.
- Monitor unusual routes and endpoint discovery attempts.

7. Framework Mapping

Framework Area	Mapping
OWASP API	API9: Improper Inventory Management
Security Control	API inventory and route governance
Evidence Result	Endpoint discovery completed

8. Sanitized Output Style for GitHub

When documenting this evidence publicly, use placeholders instead of live values. The goal is to prove methodology and security understanding without exposing secrets or private data.

```
Authorization: Bearer <REDACTED_TOKEN>
Cookie: <REDACTED_COOKIE>
email: lab-user@example.com
password: REDACTED
object_id: <CONTROLLED_LAB_ID>
redirect_uri: <REDACTED_OR_LAB_CALLBACK>
```

9. GitHub Redaction Checklist

- Bearer tokens and JWT values must be blurred or replaced with <REDACTED_TOKEN>.
- Email addresses, phone numbers, user IDs, and object identifiers should be blurred when they are not required for understanding the evidence.
- Authorization headers, cookies, session values, OAuth codes, refresh tokens, access tokens, and client secrets must never be visible in public GitHub screenshots.
- If a screenshot contains personally identifiable data, crop the view or blur the affected rows before publication.

10. Publication Note

This report is designed for GitHub portfolio use. It describes authorized lab testing only and avoids production claims. The embedded screenshots have been treated as lab evidence and should remain redacted before upload.